

Access controls worksheet

	Note(s)	Issue(s)	Recommendation(s)
Authorization / authentication	Objective: List 1-2 pieces of information that can help identify the threat: • <i>Who caused this incident? Robert Taylor Jr.</i> • <i>When did it occur? 8:29:57 am (5 days ago) last access</i> • <i>What device was used? 152.207.255.255</i>	Objective: Based on your notes, list 1-2 authorization issues: • <i>What level of access did the user have? The contractor should not have access</i> • <i>Should their account be active? Not</i> • <i>Contractor account retained Admin privileges</i> • <i>Account was not deprovisioned after contract ended</i> • <i>No monitoring or alert for payroll changes to new bank account</i>	Objective: Make at least 1 recommendation that could prevent this kind of incident: • <i>Which technical, operational, or managerial controls could help?</i> • Implement role-based access control (RBAC) • Remove admin privileges from non-full-time employees • Enforce automatic account deactivation after contract end date • Enable alerts for payroll/ account changes • Apply least privilege principle •

SOC ANALYST RESPONSE

1. Incident Summary (что произошло)

Type of incident:

Unauthorized payroll modification / suspicious financial transaction

Date & Time:

Date: 10/03/2023 Time: 8:29:57 AM

Affected system:

payroll system / AdsmEmployeeService

Description:

A payroll event was created directing funds to an unknown bank account (*FAUX_BANK*), which was not authorized by the finance manager.

2. Threat Actor Identification

User: Robert Taylor Jr.

Role: Legal attorney

Account status: Contractor

IP address: 152.207.255.255

Key observation:

This indicates a **potential insider threat or compromised account**.

3. Timeline

- Last login: 8:29:57 AM (10/03/2023) (5 days ago)
- Suspicious activity: 8:29:57 AM (Payroll event added. FAUX_BANK)
- Event recorded: 8:29:57 AM (10/03/2023)

The suspicious activity aligns with the user's last recorded access.

4. Key Findings

- The user had **excessive privileges (Admin access)**
 - The account remained active **after contract termination**
 - No validation or approval required for **payroll account changes**
 - Lack of monitoring for **suspicious financial transactions**
Access controls failed + monitoring failed
-

5. Security Issues

- Violation of **least privilege principle**
 - Improper **account lifecycle management**
 - Missing **segregation of duties**
 - Lack of **real-time alerting**
-

6. Recommendations

Access Control

- Implement **Role-Based Access Control (RBAC)**
- Remove admin access from **contractors and temporary staff**

Account Management

- Enforce **automatic deactivation** after contract end date
- Conduct regular **access reviews**

Monitoring & Detection

- Enable alerts for:
 - payroll changes
 - new bank account additions
- Log and monitor all **privileged actions**

Process Improvement

- Require **multi-level approval** for financial transactions
 - Apply **segregation of duties**
-

7. Final Assessment

This incident was likely caused by **misconfigured access controls**, allowing a non-active or low-trust user to perform high-privilege actions.

Without proper controls, similar incidents could result in **financial loss or data compromise**.